



RAPPORT QA

Test End-to-End CiviquePro

Analyse complete page par page du frontend et test integral de
l'API backend

Date : 13 juin 2026

Environnement : Next.js 16.1.3 (Turbopack) + React 19 + Prisma/SQLite

Testeur : QA Senior - 25 ans d'experience

Version : 1.0

Table des matieres

- 1.** Resume executif
- 2.** Etat du projet
- 3.** Resultats Frontend - Test page par page
- 4.** Resultats Backend/API - Test endpoint par endpoint
- 5.** Synthese des vulnerabilites de securite
- 6.** Tableau recapitulatif des anomalies
- 7.** Recommandations priorisees

1. Resume executif

Ce rapport presente les resultats d'un audit de qualite end-to-end complet de l'application CiviquePro, une plateforme de preparation a l'examen civique francais. L'audit a ete conduit par un ingénieur QA senior avec 25 ans d'experience, en suivant une methodology de test systematique couvrant l'integralite des pages frontend et des endpoints API backend. L'objectif est d'identifier les anomalies fonctionnelles, les failles de securite, les problemes d'accessibilite et les defauts d'experience utilisateur avant toute mise en production.

Indicateur	Frontend	Backend	Total
Tests executes	16 pages	80 scenarios	96
Reussis (PASS)	8	69	77
Partiels (PARTIAL)	6	-	6
Echoues (FAIL)	2	11	13
Taux de reussite	50% PASS	86.3% PASS	80.2%

Repartition par severite

Severite	Frontend	Backend	Total	Action
CRITICAL	3	2	5	Correction immediate
MAJOR	7	5	12	Correction avant production
MINOR	8	5	13	Correction planifiee
INFO	5	0	5	Amelioration continue

L'audit revele 5 anomalies critiques necessitant une correction immediate, dont une vulnerabilite XSS stocke et un probleme de protection d'accès sur la page profil. Le taux de reussite global de 80.2% est acceptable pour un environnement de developpement mais insuffisant pour une mise en production. Les 12 anomalies majeures portent principalement sur des cibles de clic sans action (boutons morts), des incoherences de validation et des conflits de mise en page sur les pages d'authentification.

2. Etat du projet

Architecture technique

CiviquePro est une application Next.js 16.1.3 utilisant le bundler Turbopack, avec React 19 pour le rendu et Tailwind CSS 4 pour le stylage. L'interface utilise la bibliotheque de composants shadcn/ui (48 composants). L'authentification est geree par NextAuth.js v4 avec une strategie JWT et 5 fournisseurs (credentials, Google, Facebook, et deux mock OAuth pour le developpement). La base de donnees SQLite est geree via Prisma ORM 6.11 avec 10 modeles. Le serveur de developpement fonctionne sur le port 3000, derriere un reverse proxy Caddy sur le port 81. La configuration output:standalone est activee pour le deploiement Docker.

Base de donnees

Table	Enregistrements	Statut
User	10+	OK
QuizResult	2	OK
LegalUpdate	24	OK
GovernmentMember	5	OK
VeilleLog	6	OK
Session	0	OK (JWT)

Probleme d'environnement identifie

Le fichier .env a ete retrouve incomplet lors de cet audit : les variables NEXTAUTH_SECRET et NEXTAUTH_URL avaient disparu malgre une correction effectuee lors de la session precedente. Ceci provoque une erreur SyntaxError: Unexpected token '<' sur toutes les pages utilisant l'authentification. La correction a ete reappliquee pour permettre les tests. Ce probleme recurrent suggere un risque de regression dans la gestion de la configuration. Il est recommande d'ajouter un fichier .env.example au depot et de verifier la presence des variables critiques au demarrage de l'application.

3. Resultats Frontend - Test page par page

Page	HTTP	Verdict	Details
/ (Accueil)	200	PASS	Page d'accueil fonctionnelle avec hero section, cartes de series QCM, 5 categories de themes, FAQ et CTA. Navigation complete avec 7 items. Meta tags presents (lang=fr, viewport, description). Pas derr...
/login	200	PARTIAL	Formulaire de connexion avec email/mot de passe, toggle de visibilite, OAuth Google/Facebook (mock). PROBLEMES : bouton "Mot de passe oublie" sans action (M), toggle mot de passe sans aria-label (m), ...
/register	200	PARTIAL	Formulaire avec nom, email, mot de passe, confirmation, CGU. Indicateur de force du mot de passe. PROBLEMES : boutons "Conditions" et "Politique" sans action ni page cible (M), pas de page legale exis...
/profil	200	FAIL	CRITIQUE : Retourne HTTP 200 pour utilisateurs non authentifies au lieu de rediriger vers /login. La redirection est uniquement cote client (useEffect), causant un flash de contenu vide. Aucun message...
/cours	200	PASS	5 cartes de cours avec descriptions et comptes de lecons. PROBLEME : les liens "Acceder au cours" pointent vers /qcm/theme/* au lieu de contenus de cours, ce qui est trompeur pour l'utilisateur (M).
/annales	200	PARTIAL	3 cartes de sessions (Janvier, Mars, Mai 2026). PROBLEME : les 3 sessions pointent vers le meme URL /examen-blanc/quiz sans differentiation. Chaque session genere le meme examen aleatoire au lieu du c...
/qcm	200	PASS	Page de selection QCM avec 5 cartes de themes, comptes de questions, contenu informatif et section FAQ. Rendu complet et fonctionnel.
/qcm/theme/principes-valeurs	200	PASS	Page de theme avec titre, 2 cartes de series, boutons "Demarrer". Contenu descriptif avec sous-themes et conseils. Les IDs numeriques (/qcm/theme/1) retournent 200 avec "Thematique non trouvee" au lie...
/qcm/quiz/principes-valeurs/principes-serie-1	200	PASS	Quiz fonctionnel avec minuteur (45:00), navigation par question, 4 options (A/B/C/D), badges de type. PROBLEME : boutons de reponse sans aria-label pour l'accessibilite (m).

/questions	200	PASS	Page de questions avec filtres par theme (40 total, 11 par theme), badges de type, liste interactive. Rendu complet.
/ressources	200	PARTIAL	3 sections (Comprendre, Preparer, Le jour de lexamen) avec cartes de ressources. PROBLEME : les cartes "Lire la suite" sont des elements sans lien ni action - cibles de clic mortes (M).
/examen-blanc	200	PASS	Page dinformation avec details de lexamen (40 questions, 5 themes, 45 min, 32/40 pour reussir), tableau de distribution des questions, bouton "Demarrer". Rendu complet.
/examen-blanc/quiz	200	PASS	Quiz dexamen blanc avec composant QuizPlayer, minuteur, navigation, 40 questions. Fonctionnel.
/veille	307	PASS	Redirection correcte vers /login?callbackUrl=%2Fveille pour utilisateurs non authentifies. Protection enforcee au niveau middleware (cote serveur). Comportement exemplaire.
/nonexistent-page	404	PARTIAL	Retourne le bon code 404 avec layout conserve. PROBLEME : le message derreur est en anglais ("This page could not be found") dans une application entierement en francais (m).

Analyse transversale

Navigation : Les 7 items de navigation sont coherents sur toutes les pages. Le lien daccueil via le logo fonctionne. Letat actif est correctement mis en evidence. Le footer est identique sur toutes les pages.

SEO : Toutes les pages ont un titre identique (CiviquePro - QCM Examen Civique 2026) et une meta description identique, ce qui est problematique pour le referencement. Chaque page devrait avoir un titre et une description uniques.

Accessibilite : Absence de lien "Skip to content" pour la navigation au clavier. Les toggles de mot de passe nont pas d'aria-label. Les boutons de reponse du quiz manquent de nom accessible. Les formulaires de login et register ont des labels correctement associes via htmlFor.

4. Resultats Backend/API - Test endpoint par endpoint

Laudit backend a consiste en 80 scenarios de test couvrant les 15 endpoints API de lapplication. Chaque endpoint a ete teste avec des scenarios de succes, dechec, validation, edge cases et securite. Lauthentification a ete verifiee sur tous les endpoints proteges. Les resultats sont presentes ci-dessous.

Endpoint	Tests	PASS	FAIL	Verdict
GET /api	3	3	0	PASS
GET /api/auth/providers-status	2	2	0	PASS
POST /api/auth/register	14	11	3	PARTIAL
POST /api/auth/callback/credentials	3	3	0	PASS
GET /api/quiz-results	2	2	0	PASS
POST /api/quiz-results	15	9	6	PARTIAL
GET /api/quiz-results/stats	3	3	0	PASS
POST /api/user/update-name	9	7	2	PARTIAL

POST /api/user/update-password	9	8	1	PARTIAL
GET /api/veille/status	3	3	0	PASS
GET /api/veille/government	2	2	0	PASS
POST /api/veille/search	2	2	0	PASS
POST /api/veille/analyze	3	3	0	PASS
POST /api/veille/apply	3	3	0	PASS
GET /api/veille/cron	2	2	0	PASS
GET /api/veille/digest	2	2	0	PASS

Anomalies critiques backend

C1 - XSS stocke dans le champ nom : Les payloads XSS comme `<script>alert(1)</script>` sont stockés sans sanitisation dans la base de données via les endpoints `/api/auth/register` et `/api/user/update-name`. Bien que React échappe automatiquement le HTML, tout rendu côté serveur ou consommation par un client non-React serait vulnérable. La sanitisation côté serveur est indispensable comme mesure de défense en profondeur.

C2 - Methode HTTP incorrecte : Les endpoints `/api/user/update-name` et `/api/user/update-password` ne supportent que POST, alors que la convention API et la documentation indiquent PUT. L'utilisation de PUT renvoie 405 Method Not Allowed. Cette violation du contrat API provoque des échecs chez tout client respectant la spécification REST.

Anomalies majeures backend

M1 - Absence de validation correctAnswers vs totalQuestions : L'endpoint `/api/quiz-results` accepte `correctAnswers=10` avec `totalQuestions=5` sans erreur. Cette incohérence corrompt l'intégrité des données de résultats.

M2 - Valeurs negatives acceptees : `totalQuestions` et `correctAnswers` négatifs sont acceptés et stockés dans la base de données. Aucune validation de plage numérique n'est effectuée.

M3 - Incohérence politique mot de passe : L'inscription accepte 6 caractères minimum, tandis que la modification exige 8 caractères minimum. Un utilisateur inscrit avec 6 caractères ne peut pas changer son mot de passe pour le même, créant une confusion significative.

M4 - Nom vide accepte à l'inscription : Un nom composé uniquement d'espaces est accepté à l'inscription mais correctement rejeté lors de la mise à jour (qui utilise `.trim()`). Incohérence de validation entre create et update.

M5 - JSON malforme retourne 500 au lieu de 400 : L'envoi de JSON malforme ou d'un corps vide sur les endpoints POST génère une erreur 500 interne au lieu d'une erreur 400 Bad Request. Cela rend impossible la distinction entre une erreur client et un crash serveur.

5. Synthèse des vulnérabilités de sécurité

Test	Résultat	Détail
Injection SQL	NON VULNERABLE	Prisma utilise des requêtes paramétrées

XSS (stocke)	VULNERABLE	Champ nom non sanitise - stockage brut
Contournement auth	NON VULNERABLE	Tous les endpoints proteges rejettent les requetes non authentifiees
CORS	OK	Pas de headers CORS permissifs
Hachage mot de passe	OK	bcrypt avec cost factor 12
Securite session	OK	JWT strategy avec secret configure
Limitation de debit	ABSENT	Aucun rate limiting detecte sur aucun endpoint
Validation entrees	INSUFFISANTE	Nombres negatifs, tailles excessives acceptees
Protection /profil	ABSENTE	Pas de middleware, redirection client-only

6. Tableau recapitulatif des anomalies

ID	Severite	Domaine	Description
C1	CRITICAL	Backend	XSS stocke - champ nom non sanitise
C2	CRITICAL	Backend	PUT vs POST - endpoints update-name/update-password
P-1	CRITICAL	Frontend	/profil retourne 200 sans auth - pas de protection
P-2	CRITICAL	Frontend	/profil redirection client-only - flash contenu vide
P-3	CRITICAL	Frontend	/profil aucun contenu pour utilisateur non authentifie
L-1	MAJOR	Frontend	Bouton "Mot de passe oublie" sans action
L-3	MAJOR	Frontend	Conflit layout Header/Footer sur pages auth split-screen
R-1	MAJOR	Frontend	Boutons "Conditions" et "Politique" sans action
R-2	MAJOR	Frontend	Aucune page legale existante
A-1	MAJOR	Frontend	3 annales identiques vers meme URL
C-1	MAJOR	Frontend	Liens "Acceder au cours" vers QCM au lieu de cours
RE-1	MAJOR	Frontend	Cartes "Lire la suite" sans lien
M1	MAJOR	Backend	correctAnswers > totalQuestions accepte
M2	MAJOR	Backend	Valeurs negatives acceptees dans quiz-results
M3	MAJOR	Backend	Incoherence politique mot de passe (6 vs 8 caracteres)
M4	MAJOR	Backend	Nom vide (espaces) accepte a l'inscription
M5	MAJOR	Backend	JSON malforme retourne 500 au lieu de 400
L-2	MINOR	Frontend	Toggle mot de passe sans aria-label
R-3	MINOR	Frontend	Champ confirmation sans toggle visibilite
T1-1	MINOR	Frontend	IDs numeriques retournent 200 au lieu de 404
Q-1	MINOR	Frontend	Boutons reponse quiz sans nom accessible
404-1	MINOR	Frontend	Page 404 en anglais dans une app francaise
SEO-1	MINOR	Frontend	Titres de page identiques sur toutes les pages
SEO-2	MINOR	Frontend	Meta descriptions identiques sur toutes les pages
A11y-1	MINOR	Frontend	Absence de lien "Skip to content"
m1	MINOR	Backend	timeUsed negatif ou excessif accepte
m2	MINOR	Backend	Pas de limite de longueur sur le nom
m3	MINOR	Backend	Email excessivement long accepte
m4	MINOR	Backend	Meme mot de passe ancien/nouveau accepte

m5	MINOR	Backend	Pas de rate limiting sur l'inscription
I-1	INFO	Frontend	Middleware deprecie - utiliser "proxy" (Next.js 16)
I-2	INFO	Frontend	Boutons OAuth en mode mock (Google/Facebook non configurés)
I-3	INFO	Frontend	API racine retourne "Hello, world!" generique
I-4	INFO	Frontend	Pas d'images dans le rendu SSR - tout est client-side
I-5	INFO	Frontend	Variable .env NEXTAUTH_SECRET recurremment perdue

7. Recommandations priorisees

P1 - Immédiate

1. Ajouter la sanitisation server-side du champ nom (strip HTML/JS tags) dans /api/auth/register et /api/user/update-name pour éliminer la vulnérabilité XSS stocke.
2. Ajouter /profil au middleware de protection (comme /veille) pour enforcer la redirection côté serveur. Ajouter un message "Veuillez vous connecter" pour l'état de chargement.
3. Corriger les endpoints /api/user/update-name et /api/user/update-password pour accepter PUT en plus de POST, ou mettre à jour la documentation API.

P2 - Avant production

1. Ajouter la validation dans /api/quiz-results : correctAnswers >= 0 et <= totalQuestions, totalQuestions > 0, timeUsed >= 0.
2. Standardiser la politique de mot de passe : minimum 8 caractères de manière cohérente entre inscription et modification.
3. Ajouter .trim() sur le champ nom à l'inscription pour correspondre au comportement de update-name.
4. Wrapper le parsing JSON dans try/catch pour retourner 400 au lieu de 500 sur JSON malformé.
5. Implémenter les actions des boutons morts : "Mot de passe oublié", "Conditions", "Politique", "Lire la suite" - ou les désactiver visuellement avec "Bientôt disponible".
6. Corriger le conflit de layout sur /login et /register : désactiver Header/Footer/CTA ou utiliser un layout alternatif.
7. Créer les pages légales minimales : /conditions-generales et /politique-confidentialite.
8. Différencier les sessions d'annales avec des URLs et des contenus distincts.
9. Corriger les liens "Accéder au cours" pour pointer vers du contenu de cours ou changer le texte en "Accéder aux QCM".

P3 - Planifie

1. Ajouter des titres et meta descriptions uniques par page.
2. Créer une page 404 personnalisée en français (not-found.tsx).
3. Ajouter un lien "Skip to content" pour l'accessibilité clavier.
4. Ajouter aria-label sur les toggles de mot de passe et les boutons de réponse du quiz.

5. Retourner 404 pour les IDs de theme numeriques invalides au lieu de 200.
6. Ajouter des limites de longueur : nom (100 caracteres), email (254 caracteres).
7. Ajouter une validation : nouveau mot de passe different de l'ancien.
8. Implementer le rate limiting sur /api/auth/register et /api/auth/signin.
9. Migrer middleware.ts vers la convention "proxy" de Next.js 16.

P4 - Amelioration continue

1. Ameliorer le contenu de /api avec les metadonnees de l'API (version, endpoints, documentation).
2. Ajouter un fichier .env.example au depot avec toutes les variables necessaires.
3. Ajouter une verification au demarrage pour les variables critiques (NEXTAUTH_SECRET, NEXTAUTH_URL).
4. Configurer les vrais fournisseurs OAuth Google/Facebook pour la production.
5. Ajouter des images optimisees dans le rendu SSR pour le SEO.